



Fing Network Security & Monitoring Platform PENETRATION TEST REPORT

Security Assessment / Penetration Testing Report
11-09-2026

Prepared By
Chander Shekher
Elite Penetration Tester
csupadhyay1011@gmail.com

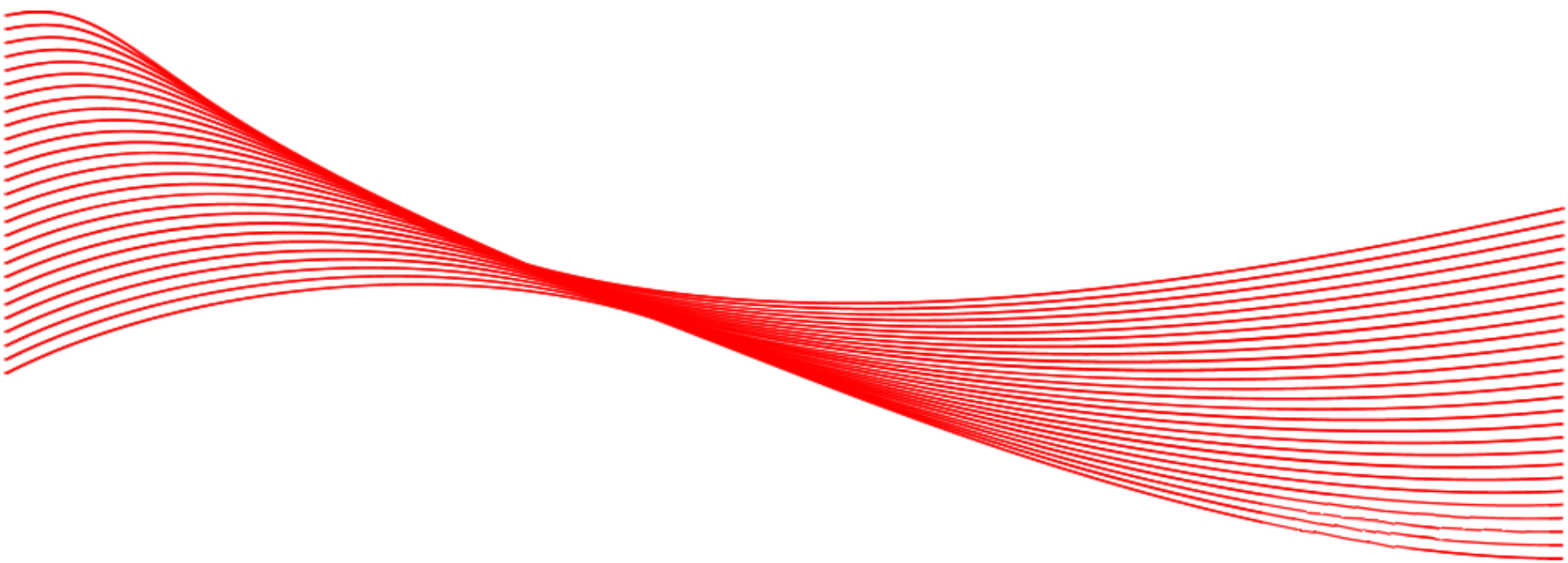




Table of Contents

Table of Contents.....2

1. Non-Disclosure Statement.....3

2. Legal Notice3

3. Executive Summary3

4. Introduction3

5. Scope4

 A. AError! Bookmark not defined.

 B. BError! Bookmark not defined.

6. Risk Rating Classification5

7. Vulnerabilities Overview.....6

8. Vulnerabilities.....7

 Improper Content Security Policy ImplementationError! Bookmark not defined.

 Misconfigured CORS Policy.....Error! Bookmark not defined.

 Improper HSTS.....Error! Bookmark not defined.

 Missing X-Content-Type Options headerError! Bookmark not defined.



Non-Disclosure Statement & Legal Notice

1. Non-Disclosure Statement

All information obtained during security assessment about Cybersec Pvt Ltd customer's systems and assets including, but not limited to, its procedures and systems, is deemed privileged information and not for public dissemination. Cybersec Pvt Ltd pledge their commitment that this information will remain strictly Public, as it is a VDP program on Integrity. This information will not be disclosed or discussed to any third party without the express written consent of the customer. Cybersec Pvt Ltd is fully committed to maintaining the highest level of ethical standards in its business practice.

2. Legal Notice

It is impossible to test for 100% security. This report does not constitute and should not be construed as a guarantee of the target's security.

3. Executive Summary

In 11-09-2026, Cybersec Pvt Ltd security engaged Fing Network Security & Monitoring Platform to perform a security assessment of implementation done by Cybersec Pvt Ltd development team. The objective of the assessment requested by Fing was to evaluate the security of Fing Network Security & Monitoring Platform which is under development by Cybersec Pvt Ltd.

During the assessment, Cybersec Pvt Ltd security identified 0 **high-risk** issues, 2 **medium-risk** issues, 2 **low-risk**, and 0 **Informational** issues.

4. Introduction

The Fing Network Security & Monitoring Platform is a network security and monitoring solution designed to provide network visibility, device discovery, monitoring, and security-related capabilities.

A Black box security audit was conducted on the Fing Network Security & Monitoring Platform in order to detect security related problems. Cybersec Pvt Ltd security reviewed Fing Network Security & Monitoring Platform under development to identify and remove any security related problem before handing over complete product to Fing.



5. Scope

The Cybersec Pvt Ltd security strategy is to test different aspects of the system completed or in progress of development phase. Security assessment was performed on the following Fing Network Security & Monitoring Platform components:

A.

1. OWASP ZAP – Passive scan.
2. Headers check manually using Burp suite proxy.



6. Risk Rating Classification

Vulnerabilities severity are supplied using DREAD framework giving an indication of their severity and are rated on a scale of five (5) to fifteen (15) using the DREAD model below

RATING	
High	12 to 15
Medium	8 to 11
Low	5 to 7
Informational	0



7. Vulnerabilities Overview

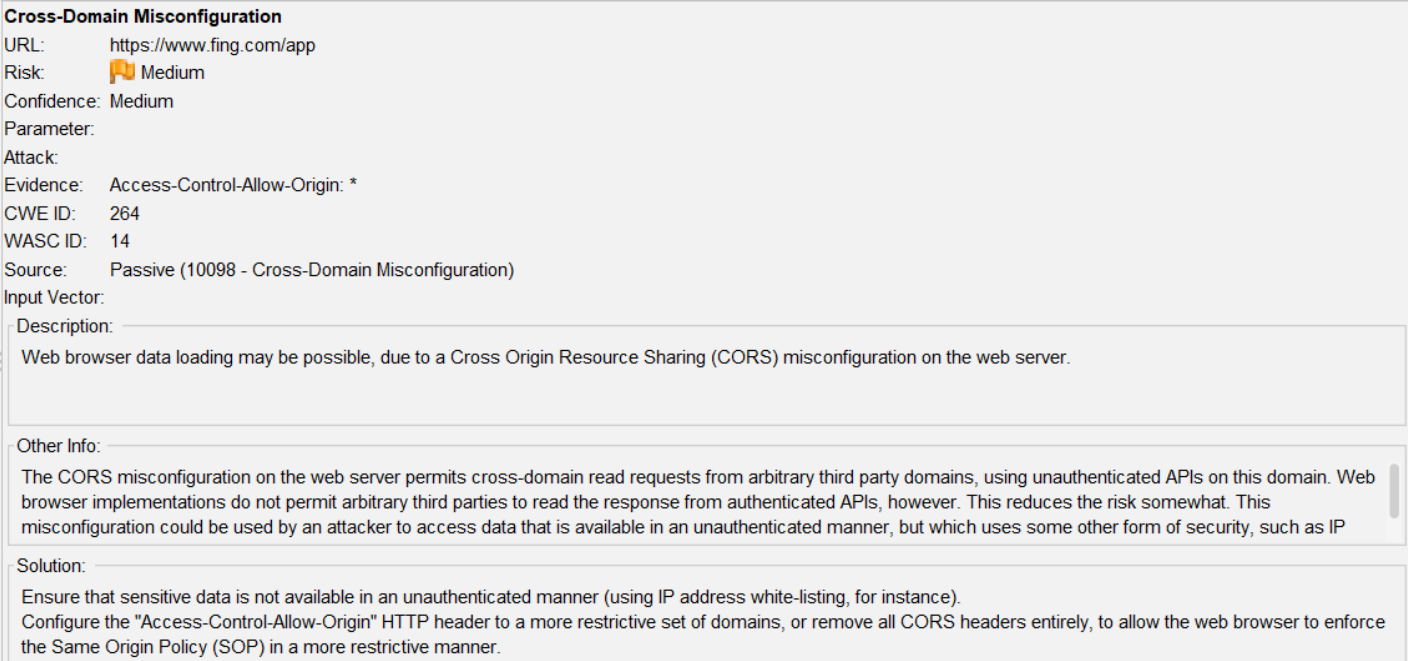
Vulnerabilities grouped by risk severity	
High	0
Medium	2
Low	2
Informational	0
Total	4



8. Vulnerabilities

1.	Improper Content Security Policy Implementation
Description	The application's Content-Security-Policy implementation is weak and provides limited protection against client-side injection attacks. Scan results identified the following issues: (1) no CSP header is set on the base response, (2) directives that fall back to default-src are not explicitly defined, so there is no consistent fallback protection, (3) the policy (where present) uses wildcard (*) source values, permitting resources from any origin, (4) script-src allows 'unsafe-eval', permitting dynamic code execution via eval(), (5) script-src allows 'unsafe-inline', permitting inline <script> execution, and (6) style-src allows 'unsafe-inline', permitting inline style injection. Together, these weaknesses mean CSP provides little to no meaningful restriction on script or resource loading.
Target	https://www.fing.com/
Risk Rating	Medium (10)
Attack techniques	An attacker who finds any injection point (e.g. a reflected/stored XSS flaw) faces no additional If an attacker identifies any injection point in the application (e.g. reflected/stored XSS, DOM-based XSS), the missing or overly permissive CSP allows injected inline scripts and styles to execute without restriction, arbitrary external domains to be used as script/resource sources due to wildcard directives, and use of eval()-based payloads (obfuscated or dynamically constructed) to bypass typical script sanitization. This significantly increases the impact and reliability of any underlying injection vulnerability.-level restriction on executing arbitrary scripts, exfiltrating data via inline requests, or loading malicious external resources, since the browser has no policy to block them.
Countermeasures	Define a Content-Security-Policy header with a strict default-src fallback (e.g. default-src 'self'). Remove wildcard (*) values and explicitly whitelist required origins. Remove 'unsafe-inline' and 'unsafe-eval' from script-src and style-src; use nonces or hashes for any required inline scripts/styles instead. Explicitly define all relevant directives (script-src, style-src, img-src, connect-src, etc.) rather than relying on defaults. Validate the updated policy using CSP Evaluator or a similar tool, and test in Content-Security-Policy-Report-Only mode before full enforcement.
Reference	CWE-693: Protection Mechanism Failure; OWASP Content Security Policy Cheat Sheet; W3C CSP Level 3 Specification
Screenshot	Alerts (14) CSP: Failure to Define Directive with No Fallback (Systemic) GET:https://www.fing.com/ GET:https://www.fing.com/app/offers GET:https://www.fing.com/wp-content/cache/min/1 GET:https://www.fing.com/wp-content/cache/min/1/wp-content GET:https://www.fing.com/wp-content/cache/min/1/wp-content/themes/fing/assets/js CSP: Wildcard Directive (Systemic) CSP: script-src unsafe-eval (Systemic) CSP: script-src unsafe-inline (Systemic) CSP: style-src unsafe-inline (Systemic) Content Security Policy (CSP) Header Not Set (Systemic) GET:https://www.fing.com/wp-content/cache/min/1/wp-content/ GET:https://www.fing.com/wp-content/cache/min/1/wp-content/plugins/sitepress-multilingual-cms/res/ GET:https://www.fing.com/wp-content/cache/min/1/wp-content/plugins/sitepress-multilingual-cms/res/ GET:https://www.fing.com/wp-content/cache/min/1/wp-content/themes/fing/ GET:https://www.fing.com/wp-content/cache/min/1/wp-content/themes/fing/assets/js/ CSP: Failure to Define Directive with No Fallback URL: https://www.fing.com/ Risk: Medium Confidence: High Parameter: Content-Security-Policy Attack: Evidence: default-src 'self'; font-src * data:;img-src * data:; frame-src * 'self' 'unsafe-inline'; worker-src blob; connect-src * 'self'; script-src * 'self' 'unsafe-inline' 'unsafe-eval'; style-src * 'unsafe-inline' 'frame-ancestors * 'self'; form-action * 'self'; CWE ID: 693 WASC ID: 15 Source: Passive (10055 - CSP) Alert Reference: 10055-13 Input Vector: Description: The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything. Other Info:



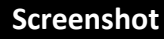
2.	Misconfigured CORS Policy
Description	Web browser data loading may be possible due to a Cross-Origin Resource Sharing (CORS) misconfiguration on the web server. The Access-Control-Allow-Origin header is set to a wildcard (*), permitting cross-domain read requests from arbitrary third-party domains via unauthenticated APIs on this domain. Browsers do not permit arbitrary third parties to read responses from authenticated APIs, which somewhat reduces the risk, but this misconfiguration could allow an attacker to access data that is available without authentication yet is protected by another control, such as IP whitelisting.
Target	https://www.fing.com/
Risk Rating	Medium (10)
Attack techniques	An attacker hosts a malicious webpage that issues cross-origin requests to the target's unauthenticated endpoints. Because Access-Control-Allow-Origin is set to *, the victim's browser permits the response to be read by the attacker's page, potentially exposing data that was intended to be restricted through mechanisms like IP-based access control rather than authentication.
Countermeasures	Ensure sensitive data is not exposed in an unauthenticated manner (e.g. relying solely on IP whitelisting). Configure the Access-Control-Allow-Origin header to a restrictive, explicit allow-list of trusted domains, or remove CORS headers entirely where cross-origin access is not required, allowing the browser to enforce the Same-Origin Policy (SOP).
Reference	CWE-264: Permissions, Privileges, and Access Control; WASC-14: Server Misconfiguration
Screenshot	

3.	Improper HSTS
Description	The application does not set the Strict-Transport-Security (HSTS) response header. HSTS instructs browsers to communicate with the website only over HTTPS, helping prevent downgrade and man-in-the-middle attacks where an attacker attempts to force an HTTP connection.
Target	https://www.fing.com/
Risk Rating	Low (7)
Attack techniques	An attacker on a position capable of intercepting network traffic may attempt an HTTPS downgrade / SSL-stripping attack if the victim initially accesses the application over HTTP. Without HSTS, the browser is not instructed to enforce HTTPS for future connections.



Countermeasures	Configure the web server/application/load balancer to return the Strict-Transport-Security header over HTTPS. Recommended example: Strict-Transport-Security: max-age=31536000; includeSubDomains after confirming that all relevant subdomains support HTTPS. Consider HSTS preload only after validating the entire domain.
Reference	CWE-319: Cleartext Transmission of Sensitive Information; WASC-15: Application Misconfiguration; RFC 6797: HTTP Strict Transport Security (HSTS)
Screenshot	

4.	Missing X-Content-Type-Options header
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
Target	https://www.fing.com/
Risk Rating	Low (7)
Attack techniques	An attacker can trick victim to perform a legitimate action on the vulnerable web application, by hiding the vulnerable application under an iframe on his site.
Countermeasures	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers



Reference:

